

SECURITY CAPSULE SIEM

ОПИСАНИЕ ПРИМЕНЕНИЯ

© ООО «Инновационные Технологии в Бизнесе», 2025.
Настоящий документ является собственностью ООО «Инновационные Технологии в Бизнесе» (далее также — ООО «ИТБ») и защищён законодательством Российской Федерации и международными соглашениями об авторских правах и интеллектуальной собственности.

Копирование документа или его фрагментов в любой форме, распространение, в том числе в переводе, а также их передача третьим лицам возможны только с письменного разрешения ООО «Инновационные Технологии в Бизнесе».

Документ может быть изменён без предварительного уведомления.
Security Capsule SIEM, Security Capsule IRP, SC SIEM являются зарегистрированными товарными знаками или товарными знаками ООО «Инновационные Технологии в Бизнесе».

Иные товарные знаки, использованные в тексте, приведены исключительно в информационных целях, исключительные права на них принадлежат соответствующим правообладателям. ООО «Инновационные Технологии в Бизнесе» не аффилировано с такими правообладателями и не производит продукцию, маркированную такими знаками.

Дата редакции документа: 24.03.2025

Версия документа: 12

АННОТАЦИЯ

Настоящий документ является описанием применения «Системы мониторинга и корреляции событий информационной безопасности Security Capsule SIEM».

СОДЕРЖАНИЕ

1 Введение 5
1.1 Общие сведения о программе 5
1.2 Область применения 5
1.3 Краткое описание возможностей 6
1.4 Уровень подготовки администратора/оператора 8
2 Выполнение требований нормативно методических документов 9
2.1 Состав мер защиты информации реализованный в SC SIEM 11
3 Архитектура SC SIEM 14
3.1 Схема развертывания 15
3.1.1 Обследование объекта информатизации 15
3.1.2 Определение перечня источников событий, подключаемых к SC SIEM 17
3.1.3 Развертывание модулей SC SIEM 19
3.1.4 Настройка модулей SC SIEM и источников событий 21
4 Корреляция событий 23
5 Выявление атак 25

1 Введение

Подход к реализации проектов с использованием системы мониторинга и корреляции событий информационной безопасности Security Capsule SIEM, а также гибкая модель лицензирования выгодно отличают данный продукт на рынке.

При выборе Security Capsule SIEM заказчики получают не только программное обеспечение, но и комплексный сервис, включающий пуско-наладочные работы и базовую настройку системы в период опытной эксплуатации.

Такой подход позволяет значительно сократить сроки внедрения и снизить затраты, что делает решение более эффективным и удобным для заказчика.

В этом разделе

- Общие сведения о программе
- Область применения
- Краткое описание возможностей
- Уровень подготовки администратора/оператора

1.1 Общие сведения о программе

Полное наименование: Система мониторинга и корреляции событий информационной безопасности Security Capsule SIEM.

Краткое наименование: SC SIEM.

SC SIEM предназначена для регистрации, учета, анализа и корреляции событий информационной безопасности с целью выявления инцидентов информационной безопасности.

Система сертифицирована в системе сертификации Федеральной службы по техническому и экспортному контролю (ФСТЭК России), что подтверждает её соответствие требованиям по защите информации. Кроме того, SC SIEM зарегистрирована в Едином реестре российских программ для электронных вычислительных машин и баз данных (Минцифры России), что свидетельствует о её отечественном происхождении и соответствии государственным стандартам.

1.2 Область применения

SC SIEM предназначена для мониторинга и корреляции событий информационной безопасности (ИБ) и может применяться в составе:

а) Государственных информационных систем (ГИС).

б) Информационных систем персональных данных (ИСПДн).

в) Автоматизированных систем управления технологическими процессами (АСУТП).

г) Объектов критической информационной инфраструктуры (КИИ).

д) В составе систем обнаружения, предупреждения и ликвидации последствий компьютерных атак (ГосСОПКА),

е) Других систем, требующих мониторинга, анализа, регистрации, корреляции событий и выявления инцидентов информационной безопасности для предотвращения недопустимых событий на объекте информатизации.

SC SIEM способствует повышению уровня информационной безопасности, обеспечивая своевременное обнаружение и реагирование на инциденты, что особенно важно для критически важных объектов и инфраструктур.

1.3 Краткое описание возможностей

SC SIEM предназначена для руководителей, администраторов и операторов безопасности, ответственных за обеспечение информационной безопасности (ИБ).

SC SIEM позволяет:

а) выполнять требования регуляторов ФСТЭК и ФСБ России по реализации системы защиты информации на объекте информатизации;

б) реализовать систему мониторинга и корреляции событий информационной безопасности на любом объекте информатизации, вне зависимости от масштаба (федеральный, региональный, объектовый);

в) осуществлять оперативную отправку уведомлений о выявленных на объекте информатизации инцидентах в Национальный координационный центр по компьютерным инцидентам (НКЦКИ);

г) осуществлять всеобъемлющий сбор событий от любых источников, осуществляющих логирование событий (например, в файл, базу данных и т.п.);

д) собирать события как с помощью агентов, так и без их применения;

е) выявлять попытки реализации недопустимых событий;

ж) производить оценку уровня защищённости информационной инфраструктуры;

з) отслеживать изменения в Active Directory и Group Policy;

и) оперативно уведомлять ответственных лиц об обнаружении инцидентов информационной безопасности;

к) экспресс-выгружать и сохранять данные о зафиксированных событиях, выявленных инцидентах и иных данных работы SC SIEM;

л) хранить информацию о событиях и инцидентах без ограничений по времени;

м) в режиме реального времени осуществлять корреляцию событий от источников, в том числе неоднородных, с целью выявления инцидентов информационной безопасности;

н) развёртывать систему в среде виртуализации;

о) устанавливать модули SC SIEM на отечественные операционные системы;

п) реализовывать систему в виде отказоустойчивого кластера;

р) организовывать ролевую модель доступа пользователей SC SIEM;

с) контролировать активность процессов, сетевых соединений и операций с файлами на конечных узлах как под управлением ОС Windows, так и Unix-подобных систем;

т) оценивать эффективность и корректность настроек применяемых средств защиты и систем защиты информации;

у) выявлять инциденты информационной безопасности в ретроспективе;

ф) контролировать действия пользователей SC SIEM;

х) масштабировать систему мониторинга и корреляции событий информационной безопасности в зависимости от потребностей бизнеса или государства;

ц) автоматически отправлять уведомления об инцидентах в НКЦКИ;

ч) обогащать инциденты данными об угрозах из системы Threat Intelligence от F.A.C.C.T.

ш) упростить работу с выявленными уязвимостями;

щ) ИИ-ассистент GigaChat помогает в обработке событий и инцидентов ИБ.

Примечание

Благодаря бессрочным лицензиям на SC SIEM исключены ситуации, при которых анализ событий, выявление инцидентов и предотвращение недопустимых событий могут быть приостановлены из-за окончания срока действия лицензии. Это обеспечивает непрерывную работу системы мониторинга и корреляции, повышая надежность защиты информационной инфраструктуры.

1.4 Уровень подготовки администратора/оператора

Квалификация оператора SC SIEM должна позволять:

а) осуществлять работы по пуско-наладке и настройке SC SIEM;

б) производить настройку и подключение источников событий к SC SIEM;

в) осуществлять анализ событий информационной безопасности от гетерогенных источников данных;

г) производить оптимизацию существующих, а также написание новых правил корреляции событий;

д) принимать меры по реагированию на инциденты информационной безопасности;

е) осуществлять взаимодействие с Национальным координационным центром по компьютерным инцидентам.

ж) формировать отчеты.

з) контролировать состояние работоспособности модулей SC SIEM.

2 Выполнение требований нормативно методических документов

SC SIEM может применяться для выполнения требований следующих нормативно методических документов:

а) выполнение требований Приказа ФСТЭК России № 21 от 18 февраля 2013 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» в части регистрации событий безопасности, а также выявления инцидентов (одного события или группы событий), которые могут привести к сбоям или нарушению функционирования информационной системы и (или) к возникновению угроз безопасности персональных данных, и реагирование на них;

б) выполнение требований Приказа ФСТЭК России № 17 от 11 февраля 2013 «Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах» в части:

1 Выявления инцидентов (одного события или группы событий), которые могут привести к сбоям или нарушению функционирования информационной системы и (или) к возникновению угроз безопасности информации, и реагирования на них.

2 обеспечение защиты информации в ходе эксплуатации информационной системы Заказчиком в соответствии с эксплуатационной документацией и организационно-распорядительными документами по защите информации включающими следующие мероприятия:

- Управление (администрирование) системы защиты информации информационной системы в части мониторинга и анализа зарегистрированных событий в информационной системе, связанных с обеспечением безопасности.
- Обнаружение и идентификация инцидентов, в том числе отказов в обслуживании, сбоев (перезагрузок) в работе технических средств, программного обеспечения и средств защиты информации, нарушений правил разграничения доступа, неправомерных действий по сбору информации, внедрений вредоносных компьютерных программ (вирусов) и иных событий, приводящих к возникновению инцидентов;
- Своевременное информирование пользователей и администраторов лицами, ответственными за выявление инцидентов и реагирование

на них, о возникновении инцидентов в информационной системе;

– Анализа инцидентов, в том числе определение источников и причин возникновения инцидентов, а также оценка их последствий.

3 Реализация в информационной системе мер по регистрации событий безопасности согласно требованиям к мерам защиты информации, содержащейся в информационной системе.

в) выполнение мер по обеспечению безопасности персональных данных при их обработке согласно Федеральному закону от 27 июля 2006 г. N 152-ФЗ «О персональных данных», а именно:

1 Обнаружение фактов несанкционированного доступа к персональным данным и принятие мер, в том числе мер по обнаружению, предупреждению и ликвидации последствий компьютерных атак на информационные системы персональных данных и по реагированию на компьютерные инциденты в них.

г) выполнение требований Приказа ФСБ России от 13 февраля 2023 г. N 77 «Об утверждении порядка взаимодействия операторов с государственной системой обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации, включая информирование ФСБ России о компьютерных инцидентах, повлекших неправомерную передачу (предоставление, распространение, доступ) персональных данных», в части обеспечения взаимодействия с государственной системой обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации, включая информирование о компьютерных инцидентах, повлекших неправомерную передачу (предоставление, распространение, доступ) персональных данных в порядке, определенном федеральным органом исполнительной власти, уполномоченным в области обеспечения безопасности;

д) выполнение требований Федерального закона от 26 июля 2017 г. N 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации», в части соблюдение режима информационной безопасности, а также правовых актов ФСБ России, таких как:

1 Приказ ФСБ России от 24 июля 2018 г. N 367 «Об утверждении Перечня информации, представляемой в государственную систему обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации и Порядка представления информации в государственную систему обнаружения, предупреждения и

ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации»;

2 Приказ ФСБ России от 19 июня 2019 г. N 282 «Об утверждении Порядка информирования ФСБ России о компьютерных инцидентах, реагирования на них, принятия мер по ликвидации последствий компьютерных атак, проведенных в отношении значимых объектов критической информационной инфраструктуры Российской Федерации»;

е) Приказ ФСБ России от 24 июля 2018 г. N 368 «Об утверждении Порядка обмена информацией о компьютерных инцидентах между субъектами критической информационной инфраструктуры Российской Федерации, между субъектами критической информационной инфраструктуры Российской Федерации и уполномоченными органами иностранных государств, международными, международными неправительственными организациями и иностранными организациями, осуществляющими деятельность в области реагирования на компьютерные инциденты, и Порядка получения субъектами критической информационной инфраструктуры Российской Федерации информации о средствах и способах проведения компьютерных атак и о методах их предупреждения и обнаружения».

В этом разделе

– Состав мер защиты информации реализованный в SC SIEM

2.1 Состав мер защиты информации реализованный в SC SIEM

В SC SIEM реализован следующий состав мер по обеспечению безопасности для значимого объекта соответствующей категории значимости согласно Приказу ФСТЭК России от 25 декабря 2017 г. N 239 «Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации»:

а) АУД.1 Инвентаризация информационных ресурсов.

б) АУД.4 Регистрация событий безопасности.

в) АУД.6 Защита информации о событиях безопасности.

г) АУД.7 Мониторинг безопасности.

д) АУД.8 Реагирование на сбои при регистрации событий безопасности.

е) ИАФ.1 Идентификация и аутентификация пользователей и инициируемых ими процессов.

ж) ИАФ.2 Идентификация и аутентификация устройств.

з) ИАФ.4 Управление средствами аутентификации.

и) ИАФ.5 Защита обратной связи при вводе аутентификационной информации.

к) УПД.1 Управление учетными записями пользователей.

л) УПД.2 Реализация модели управления доступом.

м) ИНЦ.1 Выявление компьютерных инцидентов.

н) ИНЦ.2 Информирование о компьютерных инцидентах.

о) ИНЦ.3 Анализ компьютерных инцидентов.

п) ИНЦ.6 Хранение и защита информации о компьютерных инцидентах.

В SC SIEM реализован следующий состав мер защиты информации и их базовый набор для соответствующего класса защищенности информационной системы согласно Приказу Федеральной службы по техническому и экспортному контролю от 11 февраля 2013 г. N 17 «Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах»:

а) ИАФ.1 Идентификация и аутентификация пользователей и инициируемых ими процессов.

б) ИАФ.2 Идентификация и аутентификация устройств.

в) ИАФ.4 Управление средствами аутентификации.

г) ИАФ.5 Защита обратной связи при вводе аутентификационной информации.

д) УПД.1 Управление учетными записями пользователей.

е) УПД.2 Реализация модели управления доступом.

ж) РСБ.1 Определение событий безопасности, подлежащих регистрации, и сроков их хранения.

з) РСБ.2 Определение состава и содержания информации о событиях безопасности, подлежащих регистрации.

и) РСБ.3 Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения.

к) РСБ.4 Реагирование на сбои при регистрации событий безопасности, в том числе аппаратные и программные ошибки, сбои в механизмах сбора информации и достижение предела или переполнения объема (емкости) памяти.

л) РСБ.5 Мониторинг (просмотр, анализ) результатов регистрации событий безопасности и реагирование на них.

м) РСБ.7 Защита информации о событиях безопасности.

В SC SIEM реализован следующий состав и содержание мер по обеспечению безопасности персональных данных, необходимых для обеспечения каждого из уровней защищенности персональных данных согласно Приказу ФСТЭК России от 18 февраля 2013 г. «N 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных»:

а) ИАФ.1 Идентификация и аутентификация пользователей и инициируемых ими процессов.

б) ИАФ.2 Идентификация и аутентификация устройств.

в) ИАФ.4 Управление средствами аутентификации.

г) ИАФ.5 Защита обратной связи при вводе аутентификационной информации.

д) УПД.1 Управление учетными записями пользователей.

е) УПД.2 Реализация модели управления доступом.

ж) РСБ.1 Определение событий безопасности, подлежащих регистрации, и сроков их хранения.

з) РСБ.2 Определение состава и содержания информации о событиях безопасности, подлежащих регистрации.

и) РСБ.3 Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения.

к) РСБ.4 Реагирование на сбои при регистрации событий безопасности, в том числе аппаратные и программные ошибки, сбои в механизмах сбора информации и достижение предела или переполнения объема (емкости) памяти.

л) РСБ.5 Мониторинг (просмотр, анализ) результатов регистрации событий безопасности и реагирование на них.

м) РСБ.7 Защита информации о событиях безопасности.

н) ИНЦ.1 Определение лиц, ответственных за выявление инцидентов и реагирование на них.

о) ИНЦ.2 Обнаружение, идентификация и регистрация инцидентов.

п) ИНЦ.6 Планирование и принятие мер по предотвращению повторного возникновения инцидентов.

3 Архитектура SC SIEM

SC SIEM обладает модульной архитектурой, что позволяет адаптировать систему мониторинга и корреляции событий информационной безопасности как для небольших объектов информатизации, так и для крупных территориально-распределённых инфраструктур.

Обработка событий от источников в SC SIEM осуществляется в двух режимах:

а) Режим реального времени.

б) Режим ретроспективного анализа.

Базовый состав модулей SC SIEM включает:

а) Модуль сбора.

б) Модуль нормализации.

в) Модуль корреляции.

г) Модуль хранения.

д) Консоль.

Кроме того, в SC SIEM возможна активация дополнительных лицензируемых модулей, таких как модуль ГосСОПКА, для выполнения специфических задач, связанных с информационной безопасностью.

Примечание

Модуль «Корреляции», модуль «Сбора» и модуль «Нормализации» в SC SIEM всегда устанавливаются на одном сервере. Такое объединение позволяет оптимизировать процесс обработки событий, обеспечивая их сбор, нормализацию и корреляцию в единой среде. Это сокращает задержки и повышает производительность системы при обработке событий безопасности в режиме реального времени.

Для малых объектов информатизации (до 2000 EPS) возможно развертывание модулей SC SIEM в формате All-in-one. В этом формате все основные модули SC SIEM, включая модули сбора, нормализации, корреляции и консоль, устанавливаются на один физический или виртуальный сервер. Это позволяет снизить затраты на инфраструктуру и упростить управление системой, сохраняя при этом функциональность для обработки событий и выявления инцидентов на небольших объектах информатизации.

В этом разделе

– Схема развертывания

3.1 Схема развертывания

Развертывание SC SIEM на объекте информатизации включает четыре ключевых этапа:

а) Обследование объекта информатизации.

Этот этап предполагает сбор и анализ данных о существующей инфраструктуре и политике информационной безопасности. В результате обследования формируется общая картина защищаемого объекта, на основании которой будут определены требования к SC SIEM.

б) Определение перечня источников событий, подключаемых к SC SIEM.

На этом этапе осуществляется выбор систем и устройств, которые будут отправлять данные в SC SIEM для мониторинга и корреляции. Это могут быть сетевые устройства, серверы, рабочие станции, системы безопасности и другие источники событий.

в) Развертывание модулей SC SIEM.

Данный этап включает установку и конфигурацию всех модулей SC SIEM, таких как сбор, нормализация, корреляция и консоль, в зависимости от выбранной архитектуры (All-in-one или распределённая).

г) Настройка модулей SC SIEM и источников событий.

После развертывания осуществляется настройка модулей SC SIEM, определение правил корреляции, а также конфигурирование подключаемых источников событий для их корректного взаимодействия с системой.

В этом разделе

– Обследование объекта информатизации
– Определение перечня источников событий, подключаемых к SC SIEM
– Развертывание модулей SC SIEM
– Настройка модулей SC SIEM и источников событий

3.1.1 Обследование объекта информатизации

На первом этапе развертывания SC SIEM, специалистами интегратора совместно с представителями Заказчика проводятся работы по обследованию объекта информатизации. Это обследование позволяет выявить особенности инфраструктуры, определить критические системы и компоненты, требующие защиты, а также собрать

информацию о текущем состоянии информационной безопасности. Полученные данные будут использованы для корректного планирования дальнейших этапов внедрения SC SIEM, таких как выбор источников событий, архитектуры развертывания и настройки системы для обеспечения оптимальной защиты объекта.

Примечание

Допускается проведение обследования объекта информатизации путем заполнения опросного листа. Этот подход позволяет собрать необходимую информацию о структуре объекта, его информационных системах, а также источниках событий удаленно, без необходимости физического присутствия на объекте. На основании данных, полученных из опросного листа, специалисты смогут провести предварительный анализ и подготовить план дальнейших работ по развертыванию SC SIEM.

Типовая модель территориально-распределенного объекта информатизации приведена ниже (Рисунок 1).

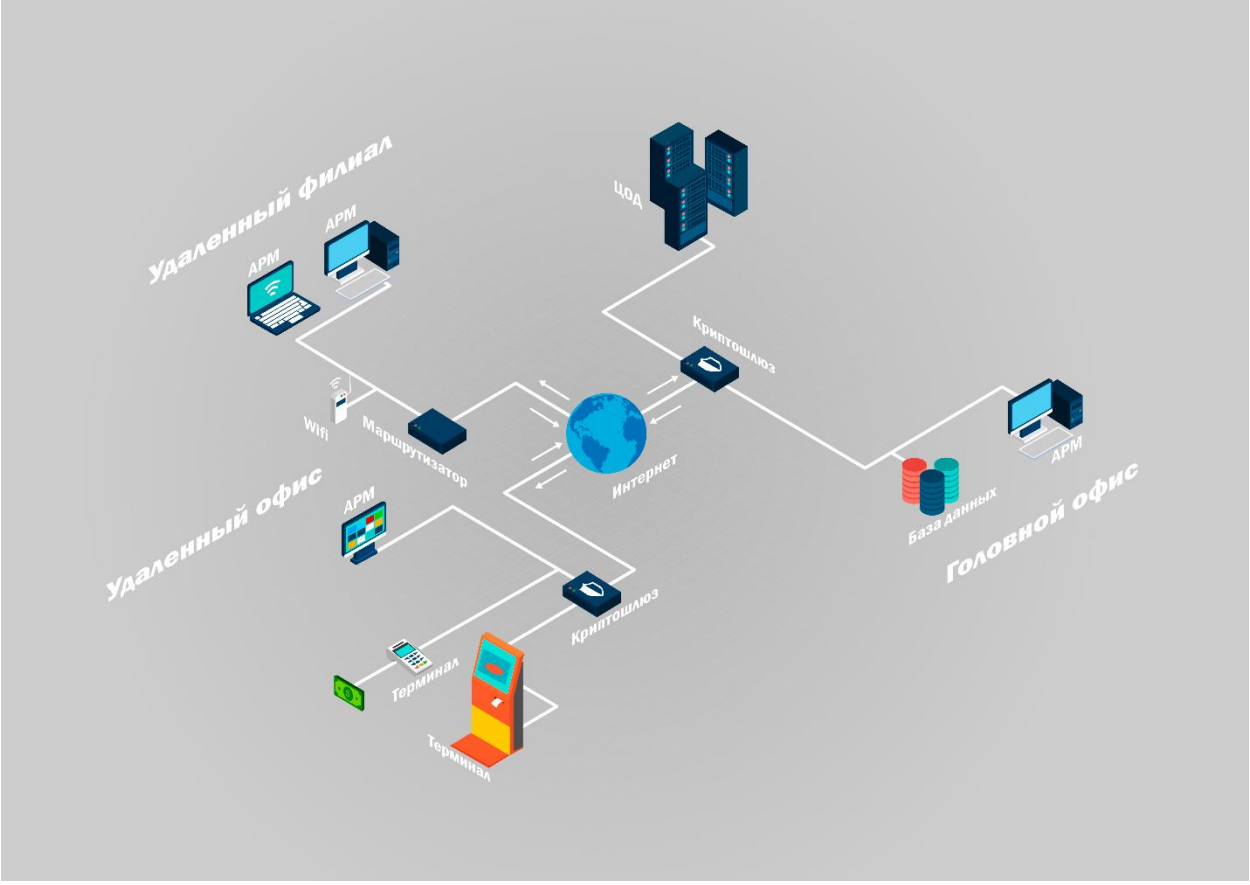


Рисунок 1 - Типовая модель территориально-распределенного объекта информатизации

3.1.2 Определение перечня источников событий, подключаемых к SC SIEM

На втором этапе развертывания SC SIEM проводятся работы по определению и согласованию перечня подключаемых источников событий. Важно учитывать, что лицензирование SC SIEM также основывается на количестве подключаемых источников событий, что необходимо учитывать при планировании системы.

Стоит отметить, что, лицензирование в SC SIEM осуществляется в том числе по количеству подключаемых источников событий. Типовые категории подключаемых источников событий к SC SIEM приведены ниже (Рисунок 2).

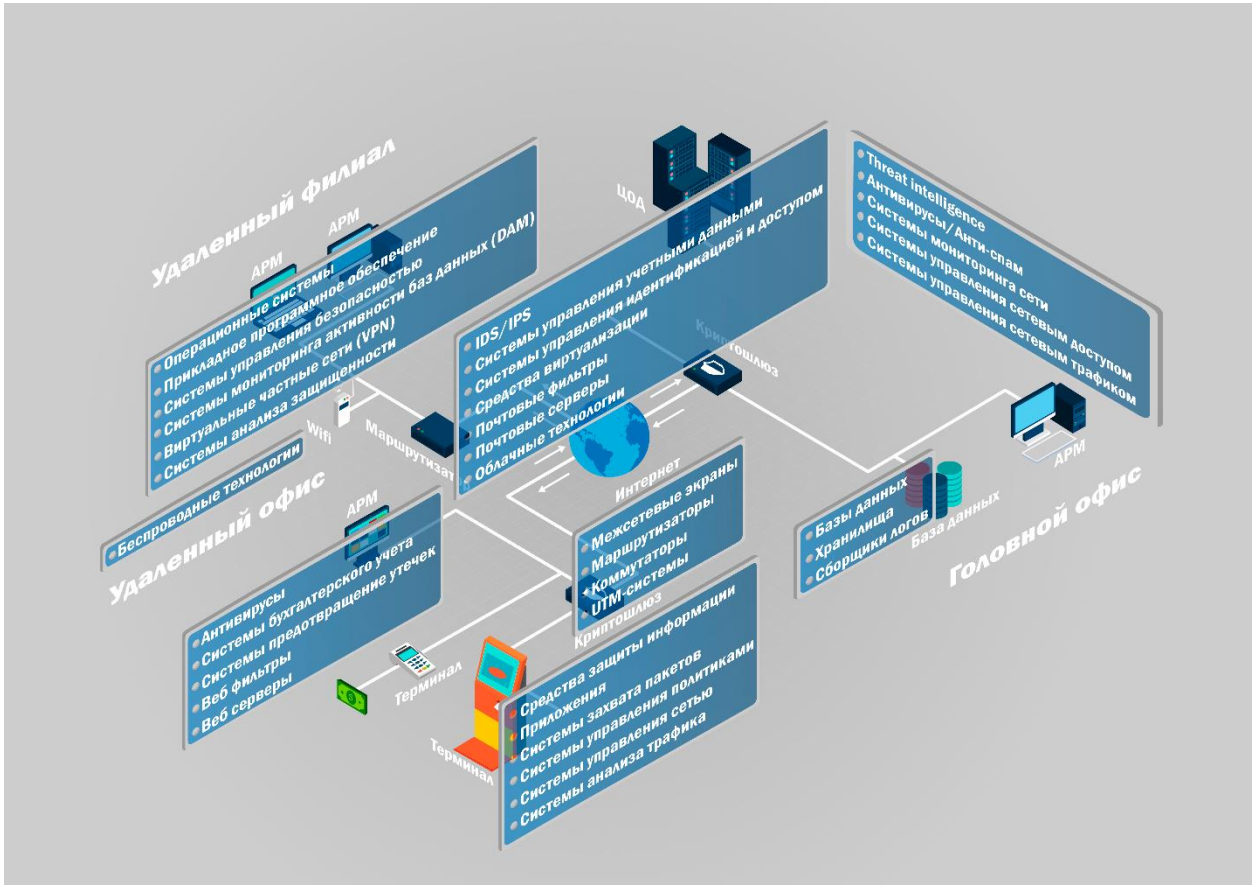


Рисунок 2 - Типовые категории подключаемых источников событий к SC SIEM

В общем виде перечень типовых категорий источников событий доступных для подключения к SC SIEM включает в себя:

а) IDS/IPS;

б) Системы управления учетными данными (IDM);

в) Системы управления идентификацией и доступом (IAM);

г) Сборщики логов (Хранилища логов);

д) Почтовые фильтры;

е) Mainframe;

ж) Почтовые серверы;

з) Системы обнаружения вредоносных программ;

и) Системы управления сетевым доступом;

к) Системы управления сетевым трафиком;

л) Операционные системы;

м) Системы класса Network Behavior Anomaly Detection (NBAD);

н) Threat intelligence;

о) Приложения;

п) Антивирусы/Анти-спам;

р) Средства защиты информации;

с) Прикладное программное обеспечение;

т) Облачные технологии;

у) Системы бухгалтерского учета;

ф) Базы данных;

х) Системы предотвращение утечек (DLP);

ц) Межсетевые экраны;

ч) Коммутаторы;

ш) UTM-систем;

щ) Средства виртуализации;

ы) Системы управления безопасностью;

э) Маршрутизаторы;

ю) Системы мониторинга активности баз данных (DAM);

я) Виртуальные частные сети (VPN);

аа) Системы анализа защищенности;

бб) Веб фильтры;

вв) Веб серверы;

гг) Беспроводные технологии;

дд) Системы захвата пакетов;

ее) Системы управления политиками;

жж) Системы управления сетью;

зз) Системы анализа трафика;

ии) Хранилища;

кк) Системы мониторинга сети.

Каждая из этих категорий требует особого внимания при настройке и согласовании источников событий, чтобы обеспечить корректную работу системы и соответствие требованиям лицензирования.

Примечание

В случае подключения к SC SIEM источника, который не поддерживает отправку событий по протоколам Syslog или SNMP-trap, предусмотрена поставка дополнительного лицензируемого коннектора. Этот коннектор предназначен для интеграции с нестандартными источниками событий, обеспечивая их корректную передачу в SC SIEM для дальнейшего анализа и корреляции.

Коннектор позволяет адаптировать формат событий от таких источников к требованиям SC SIEM, обеспечивая полноценную совместимость с системой и добавляя их в общий процесс мониторинга и обработки инцидентов

3.1.3 Развертывание модулей SC SIEM

На третьем этапе развертывания SC SIEM производится установка модулей SC SIEM в существующую инфраструктуру объекта информатизации. Этот процесс включает в себя интеграцию системы с источниками событий и настройку взаимодействия компонентов SC SIEM для обеспечения сбора, нормализации, корреляции и анализа данных. Типовая схема установки компонентов SC SIEM на территориально-распределенном объекте информатизации приведена ниже (Рисунок 3).

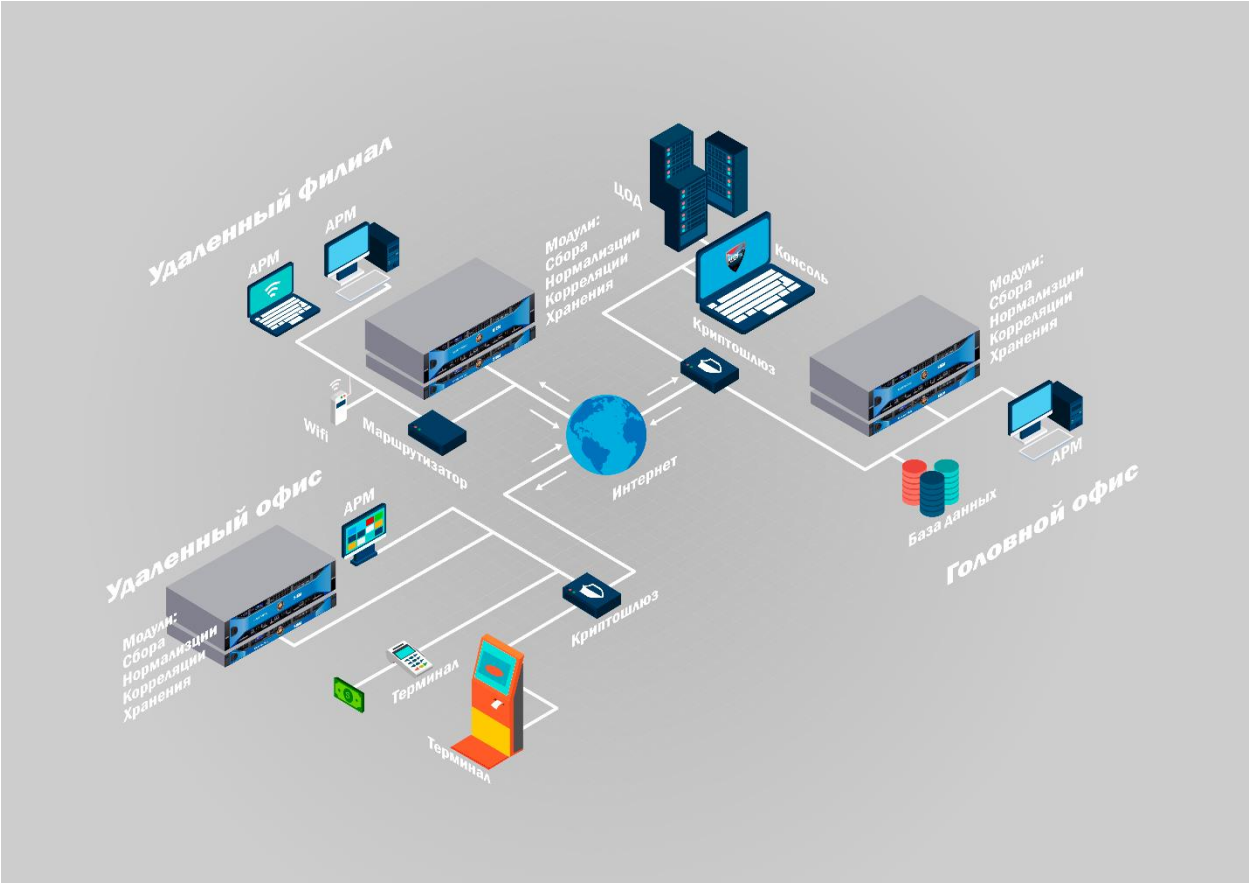


Рисунок 3 - Типовая схема установки компонентов SC SIEM на территориально-распределенном объекте информатизации

Такое распределение компонентов позволяет эффективно управлять большими объёмами данных в реальном времени, поддерживать высокий уровень безопасности на объектах с территориально-распределённой архитектурой

В случае наличия сетевой доступности и достаточной пропускной способности каналов связи между территориально-удалёнными площадками возможно реализовать централизованный сбор событий. При этом события с удалённых объектов будут передаваться непосредственно на центральный сервер SC SIEM для обработки в режиме реального времени. Такая архитектура обеспечивает:

а) Единую точку мониторинга и управления — все события собираются и анализируются в одном центре, что упрощает управление инцидентами и повышает прозрачность инфраструктуры.

б) Снижение затрат на инфраструктуру — уменьшается необходимость установки дополнительных серверов сбора и нормализации на удалённых площадках, поскольку их роль выполняет центральный сервер.

в) Оперативность обработки данных — централизованный сбор событий позволяет быстрее реагировать на инциденты и корректировать настройки системы в одном месте.

Важно учитывать, что для реализации данного подхода требуется высокая пропускная способность каналов связи, чтобы обеспечить своевременную передачу данных без задержек и потерь, особенно при обработке большого объёма событий.

Примечание

В SC SIEM поддерживается как вертикальное масштабирование за счёт увеличения аппаратных ресурсов (ЦПУ, ОЗУ, объёма хранилищ), так и горизонтальное масштабирование, предполагающее увеличение количества модулей SC SIEM для обработки возросшего объёма событий. Это позволяет гибко адаптировать систему под нужды объекта информатизации, эффективно обрабатывать события при увеличении нагрузки и сохранять высокую производительность в распределённых инфраструктурах.

3.1.4 Настройка модулей SC SIEM и источников событий

На четвёртом этапе развертывания SC SIEM проводятся работы по настройке взаимодействия между модулями SC SIEM, а также конфигурируются источники событий для передачи данных в систему. На данном этапе:

а) Определяются используемые транспорты для передачи событий (например, Syslog, SNMP, HTTP(S), FTP, агентские и безагентские методы).

б) Настраиваются правила обработки и фильтрации данных.

в) Проводится проверка корректности передачи событий от источников в SC SIEM.

Схематическое представление возможных транспортов и их взаимодействия будет отражено в соответствующей схеме ниже (Рисунок 4).

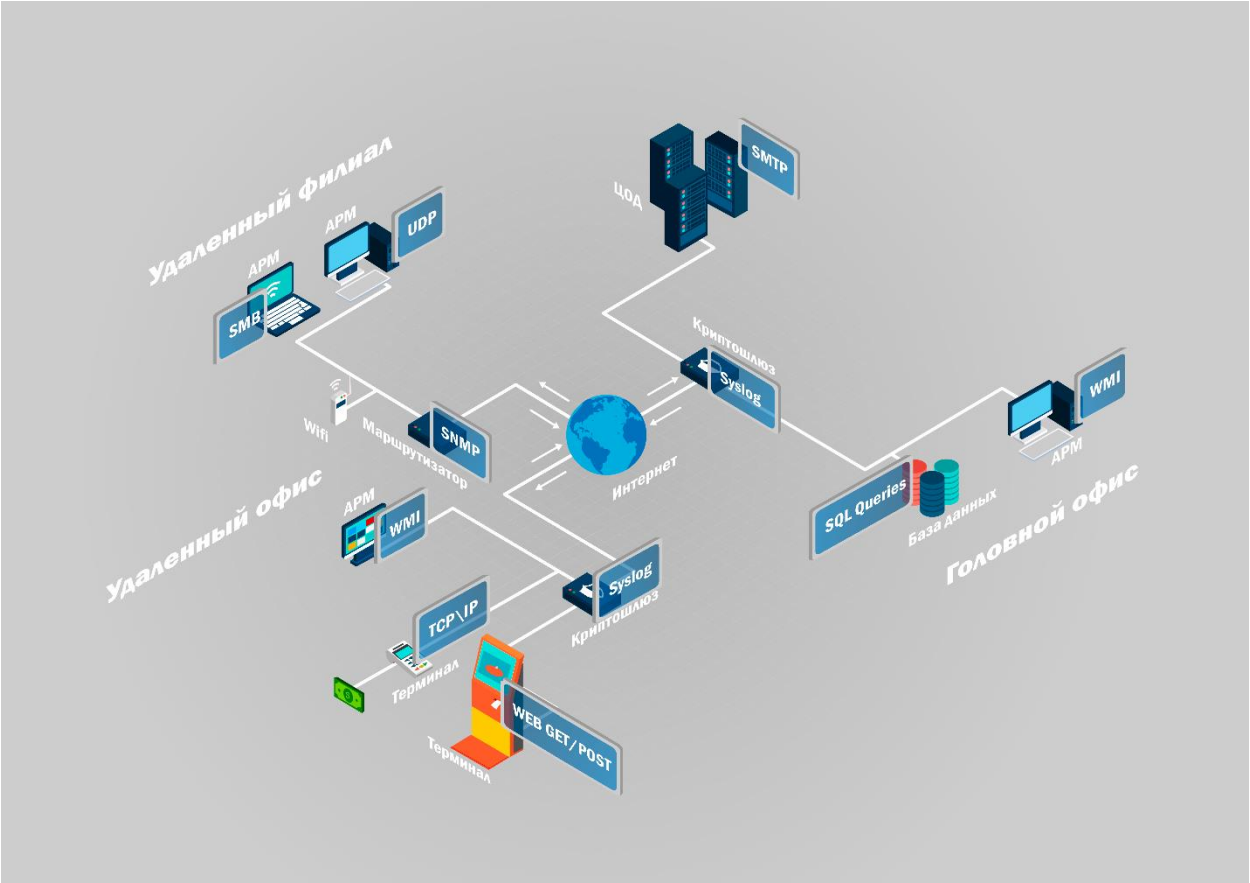


Рисунок 4 – Перечень возможных транспортов

Примечание

По результатам четвёртого этапа развертывания SC SIEM проводится этап опытной эксплуатации системы. Этот этап может включать следующие задачи:

а) Настройка и оптимизация правил нормализации данных, поступающих от источников событий.

б) Создание и адаптация правил корреляции для эффективного выявления инцидентов.

в) Проведение тестирования системы для выявления ложноположительных срабатываний (False Positive) и их последующая отработка.

г) Оценка работы SC SIEM в условиях реальной эксплуатации, выявление и исправление возможных недостатков.

Опытная эксплуатация позволяет обеспечить надёжную настройку системы перед её вводом в постоянную эксплуатацию.

4 Корреляция событий

SC SIEM включает обширную базу из более чем 2000 правил корреляции, что позволяет системе автоматически выявлять различные типы инцидентов информационной безопасности (ИБ). Ниже перечислены основные типы инцидентов, которые могут быть обнаружены с помощью существующих правил:

а) Скоррелированная атака.

б) Неудачное получение прав администратора.

в) Попытка использования.

г) Ошибка в программе.

д) Выполнение подозрительной команды.

е) Сетевое событие.

ж) Системное событие.

з) Изменение конфигурации.

и) Спам.

к) Попытка доступа к файлу или каталогу.

л) Подозрительный трафик.

м) Ошибка конфигурации.

н) Аппаратное событие.

о) Не подозрительный трафик.

п) Неизвестный трафик.

р) Потенциально опасный трафик.

с) Попытка утечки информации.

т) Утечка информации.

у) Крупномасштабная утечка информации.

ф) Попытка отказа в обслуживании.

х) Отказ в обслуживании.

ц) Попытка получения привилегий пользователя.

ч) Не успешное получение привилегий пользователя.

ш) Успешное получение привилегий пользователя.

щ) Попытка получения прав администратора.

ы) Успешное получение прав администратора.

э) Декодирование запроса RPC.

ю) Обнаружен исполняемый код.

я) Обнаружена подозрительная строка.

аа) Обнаружено подозрительное имя файла.

бб) Обнаружена попытка входа с использованием подозрительного имени пользователя.

вв) Обнаружен системный вызов.

гг) Обнаружено TCP-соединение.

дд) Обнаружен сетевой троян.

ее) Клиент использовал необычный порт.

жж) Обнаружение сканирования сети.

зз) Обнаружение атаки типа "отказ в обслуживании".

ии) Обнаружение нестандартного протокола или события.

кк) Декодирование команд общего протокола.

лл) Доступ к потенциально уязвимому веб-приложению.

мм) Атака на веб-приложение.

нн) Прочая активность.

оо) Прочая атака.

пп) Общее событие ICMP.

рр) Нарушите политики конфиденциальности компании.

сс) Попытка входа с использованием имени пользователя и пароля по умолчанию.

Примечание

В SC SIEM реализована интеграция с рядом отечественных сканеров безопасности. Эта интеграция предоставляет пользователям возможность:

а) Просматривать результаты выявленных уязвимостей в удобном виде через единый веб-интерфейс.

б) Формировать пользовательские правила корреляции на основе данных об обнаруженных уязвимостях.

Данный функционал позволяет повысить эффективность управления уязвимостями и ускорить реагирование на потенциальные угрозы, обеспечивая более глубокий анализ инцидентов в контексте выявленных слабых мест системы безопасности.

5 Выявление атак

В SC SIEM реализована возможность автоматизированного выявления атак с применением тактик и техник из модели MITRE ATT&CK. Система позволяет обнаруживать действия злоумышленников, относящиеся к следующим тактикам матрицы ATT&CK:

а) TA0043: Разведка:
   1) T1595: Активное сканирование

б) TA0042: Подготовка ресурсов:
   1) T1584: Компрометация сторонней инфраструктуры
   2) T1587: Разработка собственных средств

в) TA0001: Первоначальный доступ:
   1) T1189: Теневая (drive-by) компрометация
   2) T1190: Недостатки в общедоступном приложении
   3) T1133: Внешние службы удаленного доступа
   4) T1200: Подключение дополнительных устройств
   5) T1566: Фишинг
   6) T1195: Компрометация цепочки поставок

г) TA0002: Выполнение:
   1) T1059: Интерпретаторы командной строки и сценариев
   2) T1203: Эксплуатация уязвимостей в клиентском ПО
   3) T1559: Межпроцессное взаимодействие
   4) T1106: Нативный API
   5) T1053: Запланированная задача (задание)

6) T1569: Системные службы
7) T1204: Выполнение с участием пользователя
8) T1047: Инструментарий управления Windows

д) TA0003: Закрепление:
1) T1098: Манипуляции с учетной записью
2) T1547: Автозапуск при загрузке или входе в систему
3) T1037: Сценарии инициализации при загрузке или входе в систему
4) T1176: Расширения браузеров
5) T1136: Создание учетной записи
6) T1543: Создание или изменение системных процессов
7) T1546: Выполнение по событию
8) T1133: Внешние службы удаленного доступа

е) TA0004: Повышение привилегий:
1) T1548: Обход механизмов контроля привилегий
2) T1134: Манипуляции с токенами доступа
3) T1547: Автозапуск при загрузке или входе в систему
4) T1546: Выполнение по событию
5) T1068: Эксплуатация уязвимостей для повышения привилегий
6) T1055: Внедрение кода в процессы

ж) TA0005: Предотвращение обнаружения:
1) T1484: Изменение доменной политики
2) T1222: Изменение разрешений для файлов и каталогов
3) T1564: Сокрытие артефактов
4) T1562: Ослабление защиты
5) T1070: Устранение индикаторов
6) T1202: Непрямое выполнение команд
7) T1036: Маскировка
8) T1112: Изменение реестра
9) T1027: Обфусцированные файлы или данные
10) T1055: Внедрение кода в процессы
11) T1553: Нарушение работы средств контроля доверия
12) T1218: Выполнение с помощью системных бинарных файлов
13) T1216: Выполнение через системный сценарий
14) T1127: Выполнение через доверенные утилиты разработчика

15) T1220: Использование сценариев XSL

з) TA0006: Получение учетных данных:

1) T1056: Перехват вводимых данных
2) T1040: Прослушивание сетевого трафика
3) T1003: Получение дампа учетных данных
4) T1558: Кража или подделка билетов Kerberos
5) T1552: Незащищенные учетные данные

и) TA0007: Изучение:

1) T1087: Изучение учетных записей
2) T1482: Изучение доверительных отношений между доменами
3) T1083: Изучение файлов и каталогов
4) T1040: Прослушивание сетевого трафика
5) T1057: Изучение процессов
6) T1012: Запросы к реестру
7) T1018: Изучение удаленных систем
8) T1518: Изучение установленного ПО
9) T1016: Изучение конфигурации сети
10) T1049: Изучение сетевых подключений
11) T1033: Изучение владельца или пользователей системы

к) TA0008: Перемещение внутри периметра:

1) T1563: Перехват сессии службы удаленного доступа
2) T1021: Службы удаленного доступа

л) TA0009: Сбор данных:

1) T1560: Архивация собранных данных
2) T1123: Захват аудиоданных
3) T1115: Данные из буфера обмена
4) T1114: Email Collection \ Сбор эл. Почты
5) T1056: Input Capture \ Перехват вводимых данных

м) TA0011: Организация управления:

1) T1071: Протокол прикладного уровня
2) T1132: Кодирование данных
3) T1001: Обфускация данных
4) T1105: Передача инструментов из внешней сети
5) T1090: Прокси-сервер

6) T1219: ПО для удаленного доступа

н) TA0010: Эксфильтрация данных:

1) T1020: Автоматизированная эксфильтрация
2) T1048: Эксфильтрация по альтернативному протоколу
3) T1567: Эксфильтрация через веб-службу

о) TA0040: Деструктивное воздействие:

1) T1531: Прекращение доступа к учетной записи
2) T1485: Уничтожение данных
3) T1486: Шифрование данных
4) T1496: Несанкционированное использование ресурсов
5) T1489: Остановка службы



ООО «Инновационные Технологии в Бизнесе»
www.itb.spb.ru | итб.рус
+7 (812) 335-01-45
manager@itb.spb.ru

ООО «Инновационные Технологии в Бизнесе», 2025
Зарегистрированные товарные знаки и знаки обслуживания являются собственностью их правообладателей